ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Rockwell/Allen-Bradley ControlLogix 5570 Controller (1756-L7x) · Component type: **Embedded Device (EDR) - programmable automation controller (PAC), pre-CIP-Security generation** · Target SL = SL 3

Where to work	Program in **Studio 5000 Logix Designer** over EtherNet/IP via a **1756-EN2T / EN2TR / EN3TR / EN4TR** module (the L7 controller has **no embedded Ethernet**) or over **USB**. Access is authorized by **FactoryTalk Security** (FTSP v2.10+). On-controller controls: the **keyswitch (RUN/REM/PROG)**, **source protection** (source keys on routines/AOIs), and Rockwell-**signed firmware** via ControlFLASH Plus. There is **no controller-native CIP Security** (unlike the 5580) - for SL-3-grade comms use a **1756-EN4TR** (CIP Security via FactoryTalk Policy Manager) at the network boundary. SD card + ESM present.
Ports / paths	EtherNet/IP CIP **TCP 44818 / UDP 2222** (via the EN2T/EN4TR); comms-module embedded web **HTTP 80** (no HTTPS - disable); **USB** (Studio 5000 direct); **1756 backplane**; removable **SD card** (firmware/program). **No native CIP Security** on the L7 controller (add a 1756-EN4TR). No TLS on the controller (unauthenticated cleartext CIP).
Notes / CVEs	1756-L7x (5570). **Patch**: CVE-**2021-22681** auth-bypass (CISA **ICSA-21-056-03**) and the Logix 5370/5570 **CIP DoS** (ICSA-26-167-03, fixed in **v36.012+**); the 1756-EN2T validates signed firmware since FW **5.028**. No controller-native CIP Security / secure boot (that is the 5580) - compensate with FactoryTalk Security + keyswitch + source protection + a **1756-EN4TR (CIP Security)** + segmentation. Confirm controller + comms-module firmware.
How to read	Default read-only (Studio 5000 read-only project review; read-only CIP enumeration; controller-log / AssetCentre review). Each row = native step-by-step (FactoryTalk / keyswitch / source protection / EN4TR) + command-level external-tool validation + pass. Write/exploit tools = isolated bench + written authorization. Capable PAC but pre-CIP-Security: several rows are Partial/Compensating vs the 5580.

Project capture & evidence handling - pull BOTH the .ACD and the .L5X

Do this BEFORE working the checklist - you need BOTH files, not just the ACD upload. Going through the config screens and the logic screens requires the exported **.L5X** in addition to the native **.ACD**:
1. Upload the RUNNING program first. In Studio 5000 Logix Designer set the comms path in FactoryTalk Linx / RSLinx (**Who Active**), go **online** with the controller and **Upload** - the copy on disk may be stale versus what is actually executing. Record the controller catalog, **firmware revision**, slot, and the FactoryTalk user who may upload/download.
2. Save the .ACD (File › Save / Save As). This is the authoritative, version-matched project - needed to go back online and to see everything natively (rung/tag descriptions, AOI source, faceplates). It is **locked to the Studio 5000 major version** and is **not** human-readable or diffable.
3. ALSO export the .L5X (File › Save As → Save as type: **Logix Designer XML File (*.L5X)**, full project). The L5X is **version-independent XML** you can open, search and **diff** without the exact Studio 5000 build - this is what you actually walk for the **config screens** (Controller Properties, Module/I-O tree, Tasks/Programs, comms, controller security) and the **logic screens** (routines - ladder/FBD/ST, Add-On Instructions, tags). Grabbing only the ACD is how reviews get stuck.
4. Grab the supporting evidence too: tag + documentation export (Tools/Tags → Export to **.CSV**), the I-O module tree, Controller Properties screenshots, and on **GuardLogix** the **Safety Signature** (ID + date). Note the FactoryTalk Security roles for attribution - the controller log alone lacks user identity.
5. Name + protect the files (keep BOTH). `<site>_<zone>_<assetTag>_<catalog>_slot<n>_fw<rev>_<YYYYMMDD-HHMM>_<initials>` with the matching **.ACD** and **.L5X** extensions (and the .CSV tag export). SHA-256 hash each; store **only** on the encrypted evidence share; follow the project retention/classification policy; never email in cleartext. **Why both:** the ACD is authoritative but unusable without the matching Studio 5000 version and cannot be diffed; the L5X is the portable, reviewable, diffable record you build the checklist findings from.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 1.1	Human user identification & auth	Engineering access (go online / download / edit) is authorized by **FactoryTalk Security** (FTSP v2.10+) - confirm it is deployed and enforced. The controller's own CIP authentication had an **auth-bypass (CVE-2021-22681)** - confirm the firmware is patched; set the **keyswitch to RUN** to block remote online changes. **Test:** attempt to go online / download without FactoryTalk credentials -> denied; with the keyswitch in RUN, a download/online-edit is refused; confirm firmware not vulnerable to 22681. **Ext. tools:** FactoryTalk Admin Console (policy); Studio 5000 (go-online attempt); confirm patched firmware (`show version via RSLinx / Who Active`).	FactoryTalk Security enforces engineering access; 22681 patched; keyswitch blocks remote change.	EDR - authz via FactoryTalk; patch CVE.
SR/CR 1.2	Device & software-process I&A	EtherNet/IP CIP is **unauthenticated** on the L7 (no native CIP Security). Compensate: **Electronic Keying = Exact Match** binds module identities, restrict CIP peers by segmentation, and deploy a **1756-EN4TR (CIP Security)** so CIP peers are cryptographically authenticated at the boundary. **Test:** from an unauthorized host, open a CIP class-3 connection -> blocked by segmentation / rejected by EN4TR CIP Security. **Ext. tools:** Studio 5000 (Electronic Keying); `nmap --script enip-info -p 44818` ; Wireshark `enip || cip`; FactoryTalk Policy Manager (CIP Security on EN4TR).	Module identities keyed; CIP peers authenticated via EN4TR CIP Security; segmentation compensates.	EN4TR = CIP Security path.
SR/CR 1.3	Account management	Manage **FactoryTalk Security** users/roles (least privilege: view / edit / download / firmware), no shared logins; custody of the **source-protection keys** and the Studio 5000 project (which holds the logic). **Ext. tools:** FactoryTalk Security (user/role export); source-key custody record; project custody.	Named least-privilege FactoryTalk accounts; source keys + project controlled; no shared logins.	
SR/CR 1.4	Identifier management	Confirm a unique controller identity (name, serial, slot) and a unique **EN2T/EN4TR IP** / CIP identity; no reuse across the plant. **Ext. tools:** Studio 5000 (controller properties); `nmap --script enip-info -p 44818` ; asset register.	Unique controller + comms-module identity; no reuse.	
SR/CR 1.5	Authenticator management	Enforce the **FactoryTalk Security** password policy (length/complexity/lifetime); manage the **source-protection keys**; if the EN4TR CIP Security is used, manage its certificates/keys (FactoryTalk Policy Manager). Change all defaults. **Ext. tools:** FactoryTalk Security (password policy); source-key management; Policy Manager (cert lifecycle).	Strong FactoryTalk policy; source keys + CIP-Security certs managed; defaults changed.	
SR 1.6	Wireless access management	**N/A.** Wired controller with no native wireless interface. **Ext. tools:** Confirm no wireless on the platform.	N/A - justification recorded (wired device).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	Public key infrastructure (PKI) certificates	**Limited at the L7 controller** (no native PKI/TLS). The **1756-EN4TR** provides CIP Security X.509 certificates (asset-owner CA via FactoryTalk Policy Manager) - deploy it and confirm CA-signed certs, strong keys. Without EN4TR, record N/A + segmentation. **Ext. tools:** FactoryTalk Policy Manager (EN4TR certs); confirm no controller-native cert (L7); openssl on the EN4TR CIP-Security endpoint.	CIP Security certs via EN4TR (CA-signed, strong); L7 controller has no native PKI (compensated).	EN4TR-provided.
SR/CR 1.9	Strength of public key-based authentication	Confirm public-key authentication uses strong, current keys/algorithms. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of public key-based authentication verified individually.	
SR/CR 1.10	Authenticator feedback	Confirm FactoryTalk logon and source-key entry mask the secret (no cleartext echo). **Ext. tools:** Visual verification (FactoryTalk / Studio 5000).	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	FactoryTalk Security enforces lockout on repeated failures; the controller CIP path had the 22681 bypass (patch it); monitor failed engineering-auth + anomalous CIP at the master/IDS. **Ext. tools:** FactoryTalk Security (lockout policy); SIEM failed-auth; OT IDS on the cell.	Lockout via FactoryTalk; 22681 patched; failures monitored.	
SR/CR 1.12	System use notification	No controller banner; enforce the approved use notice on the Studio 5000 EWS (GPO) and any HMI (compensating). **Ext. tools:** EWS `gpresult /h gp.html`; HMI banner review.	Use notice at EWS/HMI (compensating at controller).	Compensating.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR 1.13	Access via untrusted networks	Segment the controller; the **EN2T/EN4TR is the boundary** - firewall CIP (44818/2222) + the web (80); no CIP from untrusted networks; remote engineering via VPN/jump host; use **EN4TR CIP Security** for authenticated remote CIP. **Test:** from an untrusted VLAN, reach 44818/80 -> must fail. **Ext. tools:** `nmap -Pn -p 44818,2222,80` from the untrusted side (expect filtered); firewall review.	Controller/comms-module unreachable from untrusted networks; remote via VPN + CIP Security.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 2.1	Authorization enforcement	Least privilege via **FactoryTalk Security** roles (view / edit / download / firmware / online-edit), the **keyswitch** (RUN blocks program changes), and **source protection** (who can view/edit routines/AOIs). Confirm a view-only user cannot download and RUN blocks online edits. **Test:** as a view-only FactoryTalk user attempt a download -> denied; with the keyswitch in RUN, attempt an online edit -> blocked. **Ext. tools:** FactoryTalk Security (role review); keyswitch test; Studio 5000 (source-protection review).	Least privilege via FactoryTalk + keyswitch + source protection; privileged actions denied.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR 2.3	Use control for portable/mobile devices	Control the Studio 5000 laptop, the controller **USB** port, and the removable **SD card**; only authorized project/firmware loaded; restrict who runs Studio 5000. **Ext. tools:** Host removable-media GPO; physical control of the USB/SD; project/firmware provenance.	Engineering media + USB/SD controlled; only authorized artifacts loaded.	
SR/EDR 2.4	Mobile code	No general-purpose mobile code; confirm only Rockwell firmware + the compiled Logix program run; **source-protect** AOIs/routines; no untrusted logic. **Ext. tools:** Studio 5000 (program/AOI review + source protection).	Only trusted firmware + reviewed/source-protected logic; no untrusted code.	EDR-specific.
SR/CR 2.5	Session lock	No controller-side session lock; enforce workstation lock on the Studio 5000 EWS (OS screen lock/GPO). **Ext. tools:** EWS inactivity-lock GPO.	EWS locks on inactivity (compensating at controller).	Compensating.
SR/CR 2.6	Remote session termination	Confirm Studio 5000 sessions can be closed and the controller/EN2T bounds concurrent CIP connections so simultaneous conflicting programming is prevented. **Ext. tools:** Studio 5000 (Who Active); `nmap --script enip-info` (connection info); Wireshark (teardown).	Sessions terminable; CIP concurrency bounded.	
SR/CR 2.7	Concurrent session control	Confirm concurrent sessions are bounded/limited and monitored. **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Concurrent session control verified individually.	
SR/CR 2.8	Auditable events	The controller has a limited **controller log** + a change-detection **audit value**; use **FactoryTalk AssetCentre** for who-changed-what change management, and a CIP-aware **OT IDS** for CIP writes/downloads; forward to the SIEM. (Controller-native audit is weaker than the 5580.) **Test:** download a change -> an AssetCentre audit entry + a change in the controller audit value. **Ext. tools:** FactoryTalk AssetCentre (change log / audit value); OT IDS + SIEM.	Changes attributable via AssetCentre + audit value; CIP events captured by IDS.	Weaker native audit - Compensating.
SR/CR 2.9	Audit storage capacity	Because audit is largely off-controller, confirm AssetCentre / IDS / SIEM are sized/retained and alert on collection failure so events are not silently lost. **Ext. tools:** AssetCentre / SIEM retention + source-silent alert.	Off-device logs sized/retained; audit-failure alerting defined.	Compensating.
SR/CR 2.10	Response to audit processing failures	Confirm a defined response to audit-processing/forwarding failures (alerting; no silent loss). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.9** above (shared steps); confirm this requirement individually and adjudicate it separately.	Response to audit processing failures verified individually.	
SR/CR 2.11	Timestamps	Confirm the controller **WallClockTime** / CST is synced (CIP time master / NTP via the EN2T) so controller-log + AssetCentre + SIEM timestamps correlate. **Ext. tools:** Studio 5000 (WallClockTime / time master); `nmap -sU -p 123 .`	Accurate synchronized controller time; events correlate.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	
EDR 2.13	Physical diagnostic & test interfaces	Control physical interfaces: locked cabinet; the **keyswitch** (set to RUN), the **USB** port, the removable **SD card**, and the **ESM** (energy storage module); shut/booted-off unused chassis interfaces. **Ext. tools:** Physical inspection (cabinet, keyswitch position, USB/SD, ESM).	Physical/diagnostic interfaces controlled; keyswitch in RUN; SD/USB secured.	EDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 3.1	Communication integrity	EtherNet/IP CIP is **unauthenticated cleartext** on the L7 and the EN2T web is HTTP - integrity/confidentiality come from a **1756-EN4TR (CIP Security)** at the boundary (authenticated + encrypted CIP) plus **containment**: keep CIP in a segmented cell and disable the EN2T web. Without EN4TR, record the gap + segmentation. **Test:** confirm CIP is CIP-Security-protected (EN4TR) or contained in-zone; EN2T web off. **Ext. tools:** Wireshark (CIP Security on EN4TR vs cleartext CIP; EN2T HTTP); `nmap -p 80,44818 .`	CIP integrity/confidentiality via EN4TR CIP Security; else contained + segmented; web off.	EN4TR closes the gap.
SR/EDR 3.2	Protection from malicious code (component)	Confirm only Rockwell firmware runs; load via **ControlFLASH Plus** from Rockwell (PCDC); the **1756-EN2T validates signed firmware since FW 5.028** and the L7 firmware is Rockwell-signed. Patch CVE-2021-22681 and the CIP DoS advisories; there is no L8-style secure-boot trust anchor. **Ext. tools:** ControlFLASH Plus (version + signature); Rockwell PSA / CISA review; confirm EN2T FW >= 5.028.	Only signed Rockwell firmware runs; signature validated; CVEs patched.	EDR-specific.
SR/CR 3.3	Security functionality verification	After any change re-verify: FactoryTalk Security, keyswitch, source protection, EN2T/EN4TR hardening + CIP Security, and firmware, against the hardening baseline; compare the Studio 5000 project (online vs offline). **Ext. tools:** Studio 5000 (compare vs baseline .ACD); `nmap -p 80,44818` ; FactoryTalk Policy Manager (CIP Security state).	Security settings match the hardening baseline after change.	
SR/CR 3.4	Software & information integrity	Protect the **Studio 5000 project (.ACD) + source keys**: host ACLs, version control; the keyswitch + FactoryTalk + source protection prevent unauthorized change; detect drift with an online-vs-offline compare + AssetCentre; hash the .ACD. **Ext. tools:** Studio 5000 (online-vs-offline compare); `certutil -hashfile .ACD SHA256`; AssetCentre.	Program integrity protected; unauthorized change prevented/detected.	
SR/CR 3.5	Input validation	Patch the Logix **CIP DoS** CVEs (ICSA-26-167-03, fixed v36.012+) and confirm the controller tolerates malformed CIP frames without a major fault. **ISOLATED only:** fuzz CIP on a bench controller and watch the controller fault state. **Ext. tools:** CIP fuzzer (`boofuzz`) on a bench controller; Wireshark; watch major/minor fault + connection state.	Known CIP CVEs patched; no fault/loss of control on malformed input.	Do NOT fuzz an in-service controller.
SR/CR 3.6	Deterministic output	**Safety-relevant row.** Verify configured fault behavior: output-module **fault action / hold-last** on controller fault or comm loss, the program's fail-safe logic, and (for safety) GuardLogix/SIL where required - so outputs assume a defined safe state. **Test:** ISOLATED: force a controller major fault / comm loss -> outputs go to the configured safe state. **Ext. tools:** Studio 5000 (module fault action / program fault routine review); bench fault injection.	Outputs go to a defined/fail-safe state on fault or comm loss.	Safety-relevant.
SR/CR 3.7	Error handling	Confirm graceful fault handling: major/minor fault routines defined, no unsafe auto-clear of a major fault, controller log records the cause, no info leak. **Ext. tools:** Studio 5000 (fault routines / controller log review).	Graceful fault handling; no unsafe auto-clear or info leak.	
SR/CR 3.8	Session integrity	**Limited on the L7.** No authenticated/encrypted CIP session natively; deploy **EN4TR CIP Security** for session integrity, else provide it by containment. Record the level. **Ext. tools:** Wireshark (CIP Security session on EN4TR vs cleartext); confirm no unauthenticated path.	Session integrity via EN4TR CIP Security; else compensating containment.	EN4TR/Partial.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 3.9	Protection of audit information	Protect the AssetCentre / IDS / SIEM store and the controller log access; restrict who can clear (FactoryTalk role); host ACLs. **Ext. tools:** AssetCentre / SIEM access review; FactoryTalk role review.	Audit records protected from unauthorized read/modify/delete.	
EDR 3.10	Support for updates	Update firmware via **ControlFLASH Plus** with Rockwell-signed firmware (PCDC); verify signature/version; patch CVE-2021-22681 + the CIP DoS (v36.012+); maintenance window with a rollback to the prior revision. **Ext. tools:** ControlFLASH Plus (signed update + version); Rockwell PCDC provenance; rollback plan.	Controlled signed updates, CVE-patched, with rollback.	EDR-specific.
EDR 3.11	Physical tamper resistance/detection	Keep the chassis in a locked/sealed cabinet; control the keyswitch, USB, SD card, and ESM; RUN keyswitch; config drift visible via AssetCentre / online-compare. **Ext. tools:** Physical inspection (cabinet/seal, keyswitch, USB/SD, ESM); AssetCentre.	Chassis secured; interfaces controlled; keyswitch in RUN; drift detectable.	EDR-specific.
EDR 3.12	Provisioning product-supplier roots of trust	**Partial.** Rockwell-signed firmware + EN2T signature validation (FW 5.028+) provide supplier trust, but the L7 lacks the L8's secure-boot trust anchor. Record the level; compensate with provenance (3.10), patching, EN4TR, physical, segmentation. **Ext. tools:** ControlFLASH signature; confirm no L8-style secure-boot on the L7.	Signed-firmware supplier trust; no secure-boot anchor (gap recorded).	EDR-specific/Partial.
EDR 3.13	Provisioning asset-owner roots of trust	The L7 controller has no asset-owner cert provisioning, but the **1756-EN4TR** provisions asset-owner CIP Security certificates (FactoryTalk Policy Manager) - use it. Without EN4TR, record N/A + network trust. **Ext. tools:** FactoryTalk Policy Manager (asset-owner CA on EN4TR); confirm enrollment.	Asset-owner RoT via EN4TR CIP Security; L7 controller compensated.	EN4TR-provided.
EDR 3.14	Integrity of the boot process	**Partial.** Signed-firmware load provides load-time integrity, but there is no L8-style secure-boot attestation on the L7. Record the gap; mitigate via signed firmware (3.10), patching, physical control, and monitoring. **Ext. tools:** ControlFLASH signature/version; confirm no secure-boot attestation on the L7.	Load-time firmware integrity; no boot attestation (gap recorded).	EDR-specific/Partial.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/repurpose, clear the program/memory (Studio 5000 clear + controller reset), erase/destroy the **SD card**, remove **source keys**, and clear the EN2T/EN4TR config so program and configuration are not recoverable. **Ext. tools:** Studio 5000 (clear controller); SD-card sanitize/destroy; EN2T/EN4TR reset; remove source keys.	Program/config/keys purged on decommission or reuse.	
SR/CR 4.3	Use of cryptography	**Limited on the L7 controller** (no native comms crypto). The **EN4TR CIP Security** provides authenticated/encrypted CIP - use it; source protection protects program IP. Compensate the rest with segmentation. **Ext. tools:** FactoryTalk Policy Manager (CIP Security ciphers); confirm EN2T web off; Wireshark.	Comms crypto via EN4TR CIP Security; source protection; segmentation compensates.	EN4TR/Partial.

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 5.1	Network segmentation	Confirm the controller + comms module sit in a segmented cell; the **EN2T/EN4TR is the boundary** - only required CIP flows (44818/2222) to authorized peers cross; use **EN4TR CIP Security** at the boundary; no flat convergence with IT. **Ext. tools:** `nmap -p 44818,2222,80` per zone; firewall + CIP-Security policy review.	Controller in a segmented cell; EN2T/EN4TR boundary enforced; only required flows cross.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	**N/A.** Controller with no general-purpose person-to-person messaging. **Ext. tools:** Confirm no such services.	N/A - justification recorded.	N/A
SR 5.4	Application partitioning	Partition by criticality: separate safety (GuardLogix) from standard control tasks/chassis where used; least-privilege FactoryTalk roles per function. **Ext. tools:** Studio 5000 (task/safety partition review); FactoryTalk role segregation.	Safety/standard and roles partitioned by criticality.	

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 6.1	Audit log accessibility	Confirm the controller log + **FactoryTalk AssetCentre** change records are readable/exportable by authorized staff and forwarded to the SIEM; a passive CIP-aware **OT IDS** on the cell captures CIP writes/downloads/CVE-exploitation. **Ext. tools:** AssetCentre (export); OT IDS (CIP-aware) on a SPAN; SIEM.	Events accessible/exportable and monitored off-controller in near-real-time.	Compensating.
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 7.1	Denial-of-service protection	The L7 is subject to **CIP DoS** CVEs - patch to **v36.012+** (ICSA-26-167-03); rate-limit/segment at the network boundary; confirm the controller keeps controlling or fails safe under a CIP flood; use ControlLogix **redundancy** where availability is critical. **Ext. tools:** ISOLATED bench: CIP flood (`hping3 --flood -p 44818 `); watch controller fault/connection state; confirm patched.	CIP DoS patched; controller stays controlling or fails safe under load; redundancy where needed.	Patch-critical.
SR/CR 7.2	Resource management	Confirm bounded resources: CIP connection limits + appropriate RPI; monitor CPU/memory (Studio 5000 Task Monitor / controller properties) so a flood cannot starve control. **Ext. tools:** Studio 5000 (connection/RPI + CPU/memory); `nmap --script enip-info`.	Resources bounded; no exhaustion-based loss of control.	
SR/CR 7.3	Control system backup	Confirm the Studio 5000 project (.ACD) + source keys + EN2T/EN4TR config are backed up (versioned, offline) and a restore is tested on a spare controller; the SD card can hold a firmware/program image for on-fault recovery. **Ext. tools:** Backup repository; `certutil -hashfile .ACD SHA256`; restore test (spare); SD image.	Backups current and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 7.6	Network & security configuration settings	Harden: FactoryTalk Security on, keyswitch in RUN, source protection set, **disable the EN2T web** + unused CIP/services, deploy **EN4TR CIP Security**, set a non-default IP, and patch controller + comms-module firmware. **Ext. tools:** FactoryTalk / Studio 5000 review; EN2T web off; `nmap -sTU -p 80,44818,2222` (only required reachable).	Least functionality; web off; CIP Security via EN4TR; keyswitch RUN; patched.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Inventory the controller (1756-L7x + firmware), the comms module (EN2T/EN4TR + firmware), and any I/O so vulnerabilities track against Rockwell PSA / CISA (CVE-2021-22681 ICSA-21-056-03; CIP DoS ICSA-26-167-03). **Ext. tools:** Studio 5000 / RSLinx (Who Active - type/firmware); `nmap --script enip-info -p 44818` ; Rockwell PSA feed.	Accurate controller/comms/firmware inventory maintained; advisories tracked.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
Studio 5000 Logix Designer + FactoryTalk Security/AssetCentre	Native authorization, project & audit review (most FRs)	FactoryTalk Security for engineering I&A + roles; Studio 5000 for program/source-protection/keying review + online-vs-offline compare; AssetCentre for change/audit. Read-only with a least-priv account.	Read/authorized project copy.
Controller keyswitch	Physical run-state control (1.1, 2.1, 2.13, 7.6)	Set the keyswitch to RUN to block remote downloads/online edits; REM/PROG only during authorized maintenance.	Physical control.
1756-EN4TR + FactoryTalk Policy Manager	CIP Security uplift (1.2, 1.8, 3.1, 3.8, 3.13, 4.3, 5.x)	Deploy a 1756-EN4TR and provision CIP Security (asset-owner CA, authenticated + encrypted CIP) via FactoryTalk Policy Manager - the SL-3 comms-security path the L7 lacks natively.	Authorized; PKI ops.
ControlFLASH Plus	Signed firmware update & provenance (3.2, 3.10)	Update the controller + EN2T/EN4TR to CVE-patched Rockwell-signed firmware (PCDC); confirm signature/version; keep the prior revision for rollback.	Maintenance window.
nmap	CIP exposure, identity & segmentation (1.x, 3.1, 5.x, 7.x)	`nmap -sTU -p 44818,2222,80` ; `nmap --script enip-info -p 44818` ; scan per zone; confirm web off/only required reachable.	Read-only; authorized.
Wireshark / tcpdump	Comms integrity & CIP Security (3.1, 3.8)	Filter `enip || cip`; confirm CIP Security (EN4TR) vs cleartext CIP; confirm EN2T web is HTTP and disabled; no cleartext creds.	Passive; SPAN/tap only.
CIP fuzzer / hping3 (isolated)	Input validation & DoS resilience (3.5, 7.1)	`boofuzz` CIP on a bench controller; `hping3 --flood -p 44818` storm; watch major/minor fault + connection state; confirm CVEs patched.	ISOLATED bench; written authorization.
Passive OT IDS + Rockwell PSA / CISA	Monitoring & vuln tracking (2.8, 6.x, 7.8)	CIP-aware IDS on the cell for writes/downloads/exploitation; track CVE-2021-22681 (ICSA-21-056-03) + CIP DoS (ICSA-26-167-03) + required firmware.	Passive; coordinate with SOC.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.